(APT Group Name) Attack Analysis Report

Prepared by: [Humphrey Wanjala]
Date: [5/20/2026]

Define the Threat Scenario

This section covers step 1 of the lab instructions.

Brief description of the attack, APT group involved, and what happened based on the scenario.

The report is a threat intelligence analysis with respect to a highly targeted cyber espionage program against a cancer research-oriented biotechnology business. The attacks are definitely the work of an advanced persistent threat (APT) from China, known as APT10, or Stone Panda/MenuPass, a well-developed group. The overall goal of the operation was to steal and to return IP (experimental data, proprietary drug formulas).

The attack took place flawlessly in 5 phases:

- First Access: Weaponized Spear Phishing Emails sent a Malicious Excel Spreadsheet (financial_report_2024.xlsm) to Corporate Users.
- Execution: When opened, it runs an automated PowerShell script to download a remote access trojan (RAT) script from a remote staging server (192.168.50.10).
- Credential Access: Once the threat actor was able to gain access, he tried to access high-privilege accounts using an online credential dumping tool, and he also dumped the LSASS process's memory to a temporary file (C:\Windows\Temp\dump.dat).
- Lateral Movement: The attackers used the valid and compromised administrator credentials to move internally using the native Remote Desktop Protocol (RDP) directly onto highly secure internal research servers (10.30.40.50).
- Finally, the targeted research data was zipped and then transmitted out via an encrypted outbound HTTPS tunnel (which was running on a non-standard port – 8443 – and to a rogue lookalike site – biotechsecure-update.com).

Map to MITRE ATT&CK Tactics and Identify Techniques

This section covers content for steps 2, 3, and 5 of the lab instructions

Complete the table as described in the lab instructions. Add additional table rows if needed.

Tactic	Technique Name	Technique ID	Description	IOCs
Initial Access	Phishing: Spearphishing Attachment	T1566.001	Delivery of malicious files via email to gain an initial foothold inside the targeted network.	Email attachment: financial_report_2024.xlsm
Execution	Command and Scripting Interpreter: PowerShell	T1059.001	Utilizing PowerShell commands to download, decode, and execute malicious payloads or scripts.	PowerShell download from: hxxp://192.168.50.10/ratscript.ps1
Credential Access	OS Credential Dumping: LSASS Memory	T1003.001	Targeting the Local Security Authority Subsystem Service (LSASS) process memory to harvest plaintext credentials or hashes.	Artifact left at local path: C:\Windows\Temp\dump.dat
Lateral Movement	Remote Services: Remote	T1021.001	Leveraging native administrative tools like	Unauthorized RDP to 10.30.40.50

	Desktop Protocol		Windows RDP to transition between compromised hosts	from IP 192.168.100.20
Command and Control	Protocol Tunneling	T1572	Tunneling malicious traffic through common, seemingly safe protocols to bypass active network security filters.	Outbound HTTPS connections over non-standard port 8443

Technique Analysis

This section covers content for step 4 of the lab.

Document your findings of each technique as described in step 4 of the lab instructions. You can document in a similar format to the example below, or you can document each technique in a paragraph format.

Example:

Spearphishing Attachment (T1566.001)

- **How it works:** A malicious macro embedded in a Word document is sent via phishing email.
- **Execution:** User enables macros → Payload runs → Attacker gains access.
- **APT33 Behavior:** Frequently employs spearphishing in initial attacks.

Phishing: Spearphishing Attachment (T1566.001)

- **How it works:** Threat actors deliver a carefully crafted email containing a weaponized attachment tailored to trap a specific target. The attachment relies on social engineering or visual prompts to coax the user into running embedded macro payloads.

- **Execution:** Employee opens attachment $\rightarrow$ Clicks "Enable Content" to view data $\rightarrow$ Visual Basic for Applications (VBA) macro initializes invisibly in the background.
- **APT10 Behavior:** APT10 relies heavily on social engineering targeted at finance, HR, and project management personnel within high-tech firms, using realistic document names (e.g., financial or regulatory reports) to hide their delivery mechanisms.

Command and Scripting Interpreter: PowerShell (T1059.001)

- **How it works:** Attackers invoke native administrative command shells like PowerShell to execute complex code strings directly in memory without compiling files on the local disk.
- **Execution:** Macro calls command line $\rightarrow$ PowerShell runs a hidden, remote script-download string $\rightarrow$ Remote Access Trojan (RAT) code executes dynamically.
- **APT10 Behavior:** The group frequently abuses built-in administrative tools ("living-off-the-land") to evade signature-based Endpoint Protection (EPP) systems, utilizing obfuscated download strings to pull their custom second-stage backdoors.

OS Credential Dumping: LSASS Memory (T1003.001)

- **How it works:** Attackers extract authentication secrets (NTLM hashes or Kerberos tickets) directly from the OS process memory space managed by LSASS.
- **Execution:** Tool runs with elevated permissions $\rightarrow$ Memory space of lsass.exe is opened and cloned $\rightarrow$ Clone file is written locally to extract admin hashes.
- **APT10 Behavior:** APT10 typically leverages credential dumpers or native Windows utilities (like comsvcs.dll via rundll32) to acquire local administrator credentials, facilitating seamless horizontal escalation across corporate workgroups.

Remote Services: Remote Desktop Protocol (T1021.001)

- **How it works:** Attackers use valid compromised credentials to log into adjacent internal network machines using the native Windows Remote Desktop platform.
- **Execution:** Threat actor connects via RDP client using stolen admin credentials $\rightarrow$ Remote system establishes an authenticated user interface session $\rightarrow$ Interactive system access is granted.
- **APT10 Behavior:** To minimize their footprint and blend in with daily IT administrative work, APT10 routinely avoids deploying excessive malware for

internal travel, prioritizing native RDP connections to target file shares and database servers.

Protocol Tunneling & Exfiltration over C2 (T1572 / T1041)

- **How it works:** Stolen data is compressed, hidden inside standard encrypted network protocols (like HTTPS), and routed out of the local network to an attacker-controlled external host.
- **Execution:** Files packed into a ZIP archive $\rightarrow$ Connection opened to an external domain over port 8443 $\rightarrow$ Hidden data streams past standard firewalls disguised as web traffic.
- **APT10 Behavior:** APT10 is known for customizing standard infrastructure protocols or using non-traditional web ports (such as 8443 or 8080) coupled with dynamic DNS or hijacked lookalike domains to bypass baseline boundary controls and silently filter large batches of research data.

Mitigation Strategies

This section covers the content from step 6 of the lab.

Complete the sections of this table.

Technique ID	Mitigation Strategy	Justification	Potential Drawback
T1566.001	Implement GPO to block macros globally from Internet sources.	Implement GPO to block macros globally from Internet sources.	May interrupt legitimate workflow if partners or vendors regularly transmit macro-enabled spreadsheets
T1059.001	Enforce PowerShell Constrained Language Mode and AppLocker code-signing.	Restricts access to core Windows API elements and prevents unapproved or unsigned scripts from executing entirely.	Can break customized administrative setup scripts used by internal IT engineering teams.
T1003.001	Enable Windows Defender Credential Guard and LSA Protection.	Isolates LSASS secrets inside a virtualized memory vault, preventing non-system processes from reading administrative credentials.	Requires modern UEFI hardware configurations and can conflict with legacy third-party authentication software.

T1021.001	Enforce network micro-segmentation and strict RDP Bastion controls.	Restricts host-to-host direct lateral traffic, ensuring access to high-value servers is filtered through a secure checkpoint with MFA.	Increases the complexity of infrastructure engineering and slightly slows administrative access response times.
T1572 / T1041	Configure strict Egress Filtering and SSL/TLS Decryption on proxies.	Restricts traffic on non-standard ports (like 8443) and decrypts outbound packets to identify hidden ZIP structures and malicious payloads.	Requires significant appliance performance overhead to parse traffic and introduces complex privacy considerations regarding inspected packets.

Monitoring and Validation

This section covers the content from step 7 of the lab.

Document how you would validate each Technique that you discovered for this attack and how you would monitor for similar attacks in the future.

Technique Validation Framework

Test the following safe tests within a controlled staging environment to ensure controls for mitigation are functioning properly:

- Validation for T1059.001 & T1566.001 (Phishing/Execution): Make an Excel file containing a harmless macro that makes a command shell or a simple ping program execute on an evil server on the network. Check to see that the macro is not able to execute and verify that the underlying shell call is denied by AppLocker.
- Try to run a utility that reads memory (e.g., the basic Microsoft Sysinternals procdump) against the PID of the lsass.exe process on the system using an administrative Test account. Make sure the handle request has been denied due to Windows Credential Guard or endpoint detection and response (EDR) software that is installed on the local machine.
- Validation for T1021.001 (Lateral Movement): Test to see if a direct RDP connection can be made between two standard workstation IPs. Be sure the connection packets are dropped at the network access control list (ACL) or at the host-level firewall before the authentication interfaces.

Future production monitoring strategy

- **Endpoint Process Monitoring:** Configure EDR rules to track parent-child process anomalies. Specifically, alert on any instance where a Microsoft Office executable (`excel.exe`, `winword.exe`) spawns downstream shells or utility applications like `powershell.exe`, `cmd.exe`, or `wscript.exe`.
- **System Event Tracking:** Centralize Windows Security log parsing inside the SIEM. Look closely for **Event ID 4624 (Successful Logon)** with **Logon Type 10 (RDP)** originating from unapproved IP subnets moving toward restricted research servers. Additionally, monitor for unexpected file creation events ending in `.dat` or `.dmp` inside root or user-profile temporary directories (`C:\Windows\Temp\`).
- **Network Flow Monitoring:** Establish protocol baselines on network edge firewalls and secure web gateways (SWG). Configure immediate indicators for outbound traffic moving over unapproved high ports (like `8443` or `8080`) that bypass normal corporate proxy paths. Implement a behavioral detection layer to flag high-volume upload streams directed toward newly registered or rarely visited lookalike domains.